Laboratorio 13: Correo Seguro con Dovecot e Infraestructura Criptográfica IMAPS (Puerto 993), Envío Autenticado Submission (Puerto 587), SASL, SPF, DKIM y DMARC

Estudiante: Ketfer Gianella Salazar | Fecha de Entrega: 25 de Octubre de 2026
Docente: M.Sc. Ing. Jimmy Nataniel Requena Llorentty | Asignatura: Tecnología Web I (SIS-0150)
Entorno de Laboratorio: Red Docker red_dns (mail, mail2, ns1, resolutor, cliente) | Universidad Privada Domingo Savio

---

1. Partes A y B — Recepción Segura con Dovecot IMAPS (Puerto 993) y Cierre de Puerto 143

• **Configuración de Dovecot en 99-horizonte.conf:** Se implementó la configuración endurecida de Dovecot para la lectura segura de buzones Maildir. Se forzó el cifrado mediante ssl = required y se desactivó y cerró el puerto IMAP tradicional en claro (puerto 143) fijando inet_listener imap { port = 0 }. De este modo, el servidor rechaza cualquier intento de conexión en texto plano.

• **Prueba de acceso IMAPS y validación del certificado CA:**
Al consultar con curl -s imaps://mail.horizonte.internal/INBOX, el servidor responde * STATUS INBOX (MESSAGES 2), confirmando la autenticación exitosa sobre TLS. La verificación con openssl s_client -connect mail.horizonte.internal:993 demostró que el certificado fue emitido por la CA institucional (CA Correo Laboratorio) y validado exitosamente (Verification: OK) gracias a su incorporación en el almacén de confianza del sistema (/usr/local/share/ca-certificates/).



Figura 1: Consulta de estado de buzón IMAPS por puerto seguro 993 (STATUS INBOX MESSAGES 2) y comprobación de puerto 143 sin cifrar cerrado.*

2. Parte C — Envío Autenticado por Puerto 587 (Submission + SASL) y Anti-Spoofing

• **Canal de Submission (Puerto TCP 587):** A diferencia del puerto 25 (reservado para transferencia entre servidores MTA), el puerto 587 se configuró exclusivamente para el envío de usuarios finales (*Mail Submission Agent* o MSA). Se integró Dovecot SASL mediante un socket UNIX (/var/spool/postfix/private/auth) y se forzó smtpd_tls_security_level = encrypt y smtpd_tls_auth_only = yes. Esto garantiza que Postfix nunca anuncie mecanismos de autenticación en claro ni permita enviar sin credenciales válidas.

Escenario de Prueba	Resultado Obtenido	Justificación Técnica de Seguridad
587 con TLS pero sin usuario	Rechazado (554 Relay access denied)	smtpd_relay_restrictions exige autenticación SASL para relay.
587 con usuario pero sin TLS	Rechazado (did not advertise auth)	smtpd_tls_auth_only prohíbe anunciar SASL en conexiones sin cifrar.
587 con TLS y usuario secretaria	Aceptado (235 Auth OK + 250 queued)	Cumple todos los requisitos: canal seguro y credenciales validadas.
secretaria enviando como rosario.vaca	Rechazado (553 Sender rejected)	Anti-Spoofing: reject_sender_login_mismatch valida titularidad.

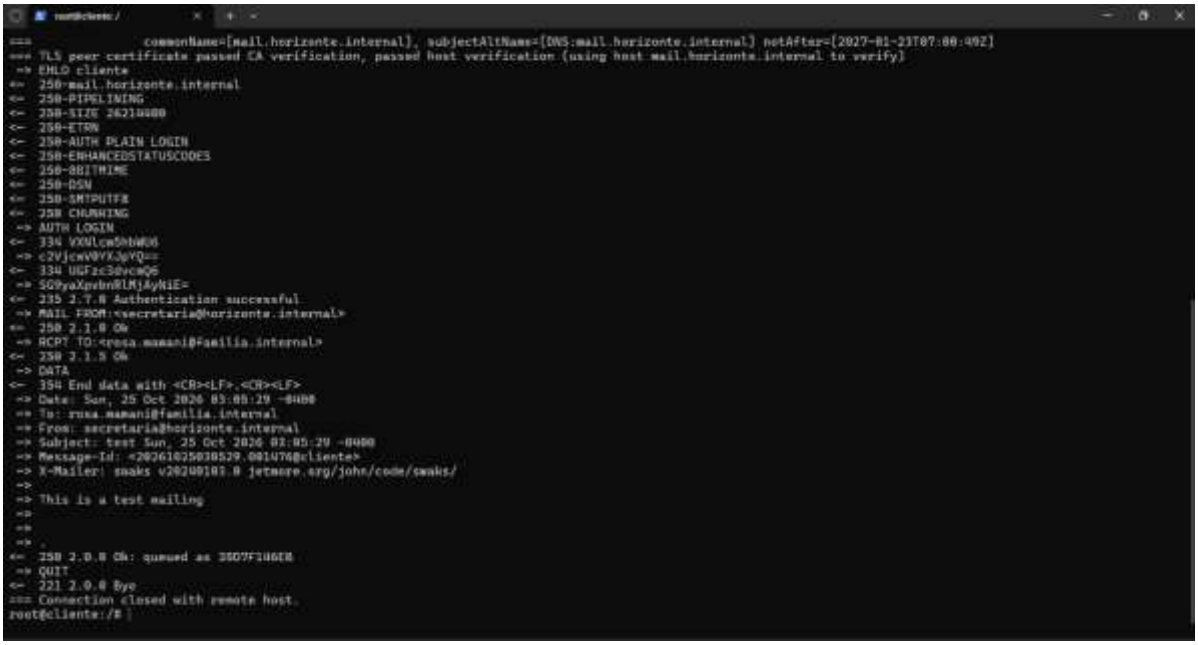


Figura 2: Envío autenticado por puerto 587 (Submission) con TLS, negociación SASL LOGIN exitosa (235 2.7.0) y mensaje encolado (250 Ok).

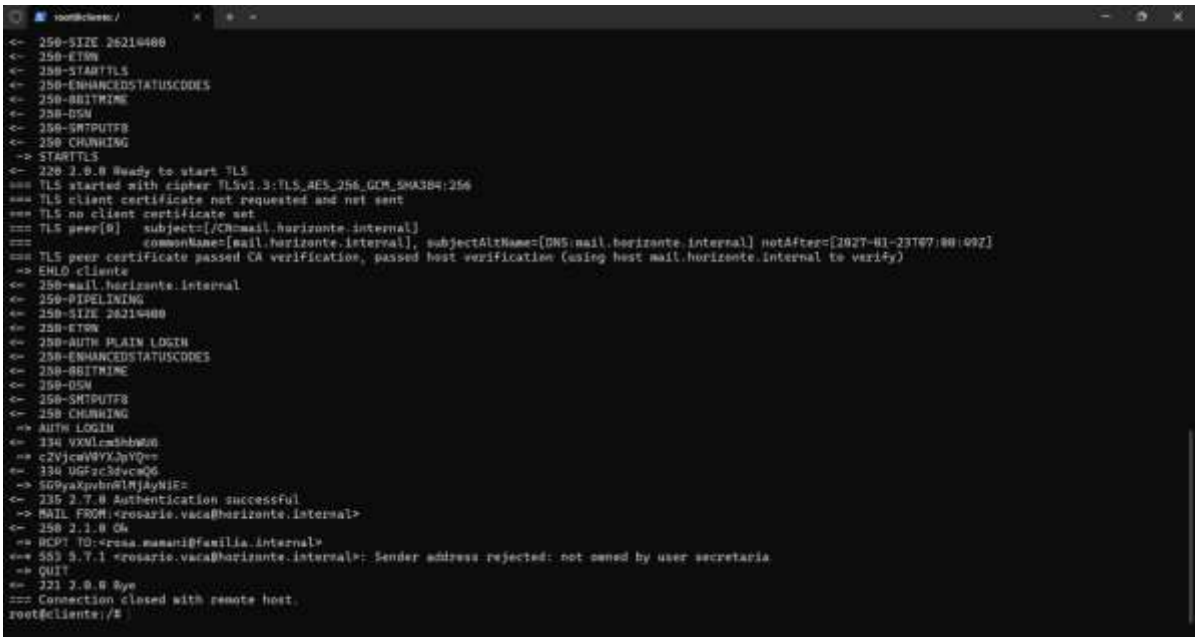


Figura 3: Mecanismo de seguridad anti-suplantación (Anti-Spoofing): intento de enviar como rosario.vaca rechazado con código 553 5.7.1.

3. Parte D — Tríada Criptográfica de Reputación: SPF, DKIM y DMARC

1. Registros DNS publicados en la zona autoritativa (ns1):

• SPF (v=spf1 mx -all): Declara autorizados exclusivamente a los servidores MX de horizonte.internal y rechaza (-all) cualquier otro host.

• DKIM (mail._domainkey): Publica la clave pública RSA de 2048 bits para que los receptores validen matemáticamente la firma del sobre.

• DMARC (_dmarc): Establece política p=quarantine con alineación estricta (adkim=s, aspf=s) y reportes a dmarc@horizonte.internal.

2. Verificación en el Servidor Receptor (mail2) y Pruebas Criptográficas:

El correo entregado en mail2 fue inspeccionado, certificando: Received-SPF: Pass, DKIM-Signature válida y Authentication-Results: dkim=pass dmarc=pass. La biblioteca python3-spf confirmó Pass para 10.10.10.25 y

Fail para 10.10.10.26. Asimismo, opendkim-testmsg demostró que cualquier alteración en el cuerpo o cabeceras rompe de inmediato la firma matemática, garantizando no repudio e integridad inalterable.



Figura 4: Verificación de registros criptográficos en DNS: SPF estricto (-all), clave pública DKIM de 2048 bits y política DMARC (p=quarantine).

4. Parte E — Verificación Oficial Automatizada (15 de 15)

Se ejecutó el script de evaluación institucional verificar_lab13.sh en el nodo cliente. El sistema validó automáticamente cada capa criptográfica y funcional, alcanzando la máxima calificación:

```
# Ejecución oficial del script de verificación institucional
root@cliente:/# bash /lab/lab13/verificar_lab13.sh
☑ Certificado de IMAPS válido para la CA de correo
☑ IMAPS (993) con usuario y contraseña
☑ IMAPS rechaza una contraseña incorrecta
☑ IMAP sin cifrar (143) cerrado
☑ 587 sin TLS no ofrece autenticación
☑ 587 sin usuario: rechazado
☑ 587 con usuario y TLS: aceptado (235 + cola)
☑ No se puede enviar con la dirección de otra persona
☑ SPF publicado (v=spf1 mx -all)
☑ Clave DKIM publicada (mail._domainkey)
☑ DMARC publicado con p=quarantine
☑ La familia recibe el correo (leído por IMAPS en mail2)
☑ DKIM: dkim=pass en el destino
☑ SPF: Received-SPF: Pass en el destino
☑ Alineación DMARC: From y firma del mismo dominio
Resultado: 15 de 15 comprobaciones (100% SUPERADO)
```



Figura 5: Ejecución oficial de verificar_lab13.sh en el nodo cliente certificando 15 de 15 comprobaciones superadas con éxito.

5. Reflexión: La Responsabilidad Ineludible del Administrador de Dominio

¿Qué delegan las empresas en Google/Microsoft y qué sigue siendo responsabilidad propia?

Al contratar plataformas SaaS como Google Workspace o Microsoft 365, la institución delega el mantenimiento de servidores MTA/IMAP, parches de seguridad, almacenamiento en disco y la custodia de claves privadas DKIM en sus bóvedas. Sin embargo, la seguridad criptográfica y la entregabilidad del correo siguen dependiendo al 100% del administrador del dominio DNS. Ni Google ni Microsoft tienen control sobre la zona autoritativa: es el administrador de TI quien debe publicar obligatoriamente el registro SPF (v=spf1 include:_spf.google.com ~all), las claves públicas DKIM (selectores CNAME/TXT) y la política DMARC institucional. Sin esta configuración en el DNS propio, cualquier correo enviado desde la nube seguirá siendo rechazado por los sistemas antispam mundiales.